

CASO OPERACIONAL CANÔNICO — PRIVACIDADE, PROTEÇÃO DE DADOS PESSOAIS E GOVERNANÇA DE INFORMAÇÕES SENSÍVEIS — VERSÃO INICIAL

1. Objetivo do caso

Validar o comportamento do sistema diante de requisitos de:

- privacidade institucional;
- proteção de dados pessoais;
- minimização de exposição de informações;
- segregação de acesso sensível;
- retenção temporal controlada;
- conformidade regulatória e jurídica.

Este caso deverá validar:

- controle granular de acesso;
- anonimização e pseudonimização;
- proteção de biometria e geolocalização;
- rastreabilidade de visualização de dados;
- retenção e descarte seguro;
- equilíbrio entre auditoria e privacidade.

2. Contexto operacional

Instituição:

- manipula dados altamente sensíveis;
- precisa cumprir normas de proteção de dados;
- necessita preservar auditabilidade sem exposição indevida.

Sistema:

- armazena biometria, localização, jornadas e decisões administrativas;
- deve limitar acesso conforme finalidade;
- deve separar observabilidade operacional de exposição pessoal.

3. Capacidades operacionais envolvidas

Sistema deve suportar:

- segregação de dados sensíveis;
- controle contextual de acesso;
- mascaramento de informações;
- retenção temporal configurável;
- anonimização para análise estatística;
- trilha auditável de acesso a dados pessoais.

4. Cenário inicial

Situação:

- auditor solicita análise de inconsistências;
- operador administrativo tenta acessar biometria completa;
- supervisor precisa apenas de interpretação operacional;
- geolocalização detalhada possui restrição institucional;
- período legal de retenção de dados está expirando.

5. Eventos conhecidos

Eventos:

1. Solicitação de acesso administrativo
2. Consulta parcial autorizada
3. Tentativa de acesso a dado sensível restrito
4. Geração de log de auditoria de acesso
5. Processo de anonimização histórica
6. Expiração de período de retenção legal

6. Evidências disponíveis

Evidências disponíveis:

- políticas de acesso;
- perfis administrativos;
- logs de visualização;
- classificação de sensibilidade dos dados;
- regras de retenção temporal;
- histórico de anonimizações.

7. Comportamento esperado do sistema

O sistema deverá:

- restringir acesso conforme finalidade e perfil;
- proteger biometria e localização sensível;
- registrar toda visualização de dados críticos;
- anonimizar dados quando permitido;
- impedir exposição desnecessária;
- preservar auditabilidade sem comprometer privacidade.

8. Possíveis interpretações

Possíveis interpretações:

- acesso legítimo para auditoria;
- excesso de privilégio administrativo;
- necessidade operacional justificada;
- tentativa indevida de inspeção pessoal;
- uso estatístico sem identificação individual.

9. Possíveis inconsistências

Possíveis inconsistências:

- acesso sem autorização adequada;
- exposição indevida de biometria;
- retenção além do prazo legal;
- anonimização incompleta;
- divergência entre política e implementação.

10. Possíveis pendências

Possíveis pendências:

- revisão de permissões administrativas;
- reclassificação de sensibilidade;
- ajuste de política de retenção;
- auditoria de acessos realizados;
- atualização normativa institucional.

11. Possíveis justificativas

Possíveis justificativas:

- auditoria institucional;
- investigação formal;
- obrigação legal de retenção;
- necessidade operacional legítima;
- conformidade regulatória.

12. Possíveis decisões administrativas

A administração poderá:

- conceder acesso excepcional;
- restringir visualização de determinados dados;
- anonimizar conjuntos históricos;
- eliminar dados após prazo legal;
- bloquear operadores com privilégio excessivo.

13. Impactos temporais esperados

Possíveis impactos:

- expiração gradual de retenção;
- anonimização de históricos antigos;
- limitação progressiva de acesso;
- preservação parcial para auditoria.

14. Impactos no banco de horas

Banco de horas poderá:

- permanecer íntegro após anonimização;
- preservar apenas cálculos derivados;
- perder vínculo identificável após retenção expirada;
- manter trilha institucional sem exposição pessoal.

15. Comportamento esperado em reproprocessamento

Reprocessamentos posteriores deverão:

- respeitar restrições de privacidade vigentes;
- evitar reidentificação indevida;
- manter rastreabilidade institucional mínima;
- preservar conformidade regulatória.

16. Comportamento esperado após fechamento

Após fechamento:

- dados sensíveis devem seguir política de retenção;
- anonimizações devem ser auditáveis;
- exclusões devem preservar integridade institucional mínima;
- histórico administrativo deve continuar verificável.

17. Riscos arquiteturais observados

O sistema deve evitar:

- exposição excessiva de dados pessoais;
- privilégio administrativo irrestrito;
- retenção indefinida desnecessária;
- reidentificação indireta;
- ausência de rastreabilidade de acesso.

18. Ambiguidades relevantes

Possíveis ambiguidades:

- equilíbrio entre auditoria e privacidade;
- anonimização reversível vs irreversível;
- retenção institucional vs direito de eliminação;
- granularidade adequada de mascaramento.

19. Observações importantes

Este caso valida:

- proteção estrutural de dados sensíveis;
- governança de privacidade institucional;
- equilíbrio entre transparência e confidencialidade.

Também valida:

- conformidade regulatória;
- segurança jurídica da plataforma;
- maturidade de proteção informacional.

Este caso possui forte relação com:

- LGPD;
- governança de dados;
- segurança da informação;
- compliance regulatório;
- proteção de identidade digital.